Processo Trainee 26/2 – SACI

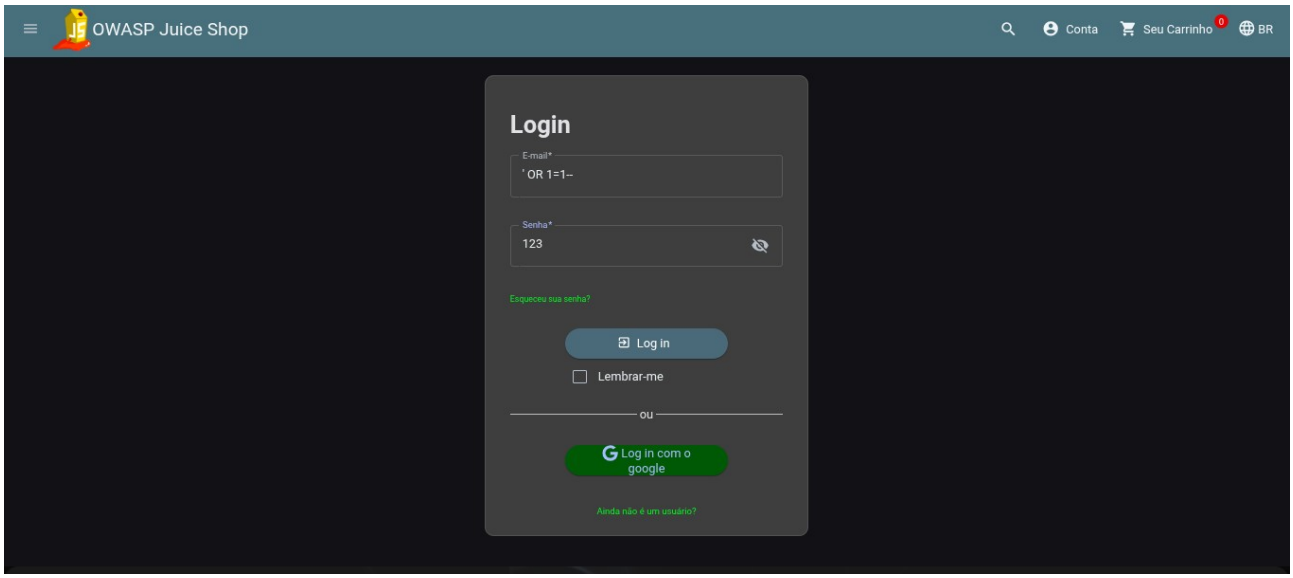
BLOCO 2:

João Vitor Rezende Marciano

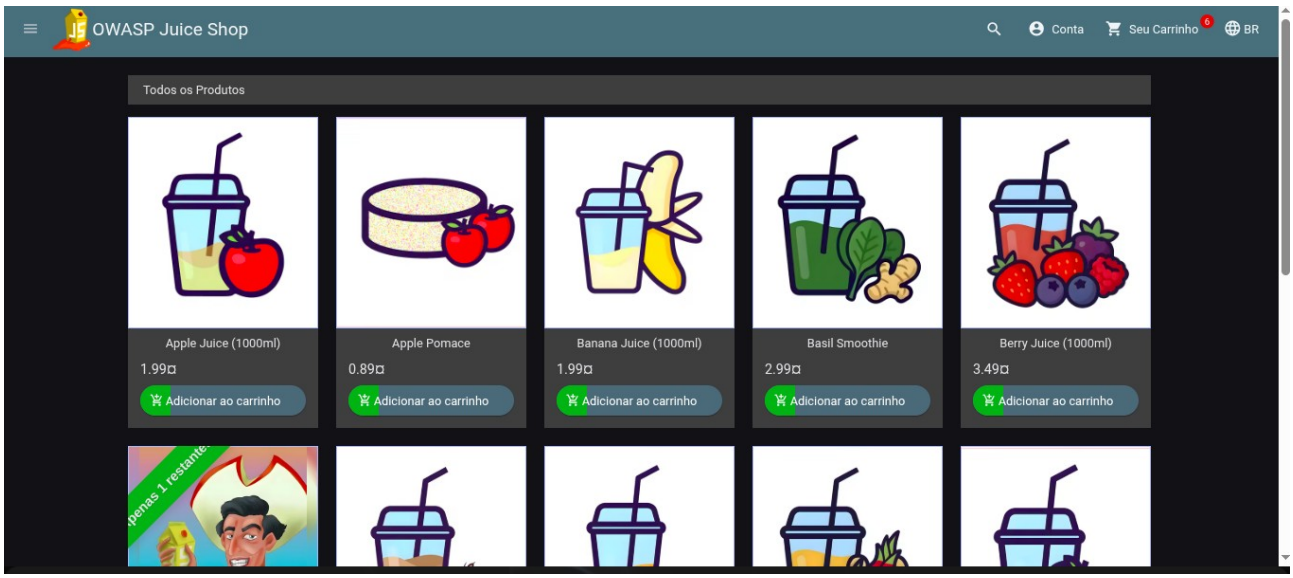
Teste de vulnerabilidades do Juice Shop.

Teste 1: SQL injection no login:

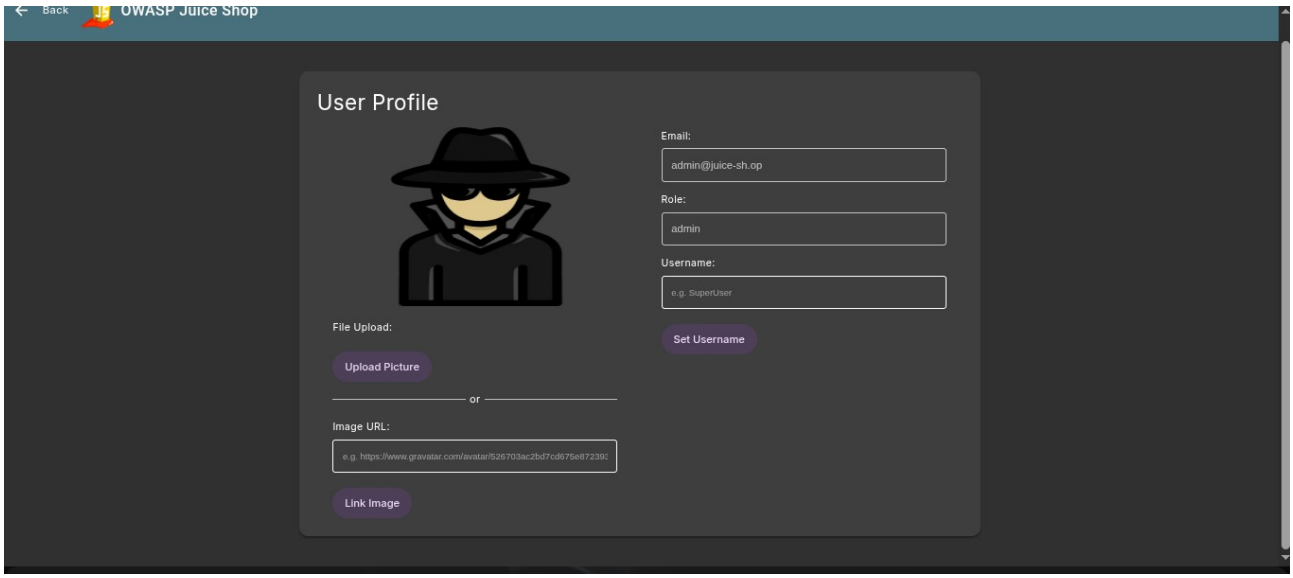
Inserir no campo de e-mail: 1 OR 1=1-- e colocar qualquer senha. O objetivo é alterar a query feita no login e conseguir entrar sem saber a senha.



Resultado:



Foi possível entrar no site, na conta de admin.

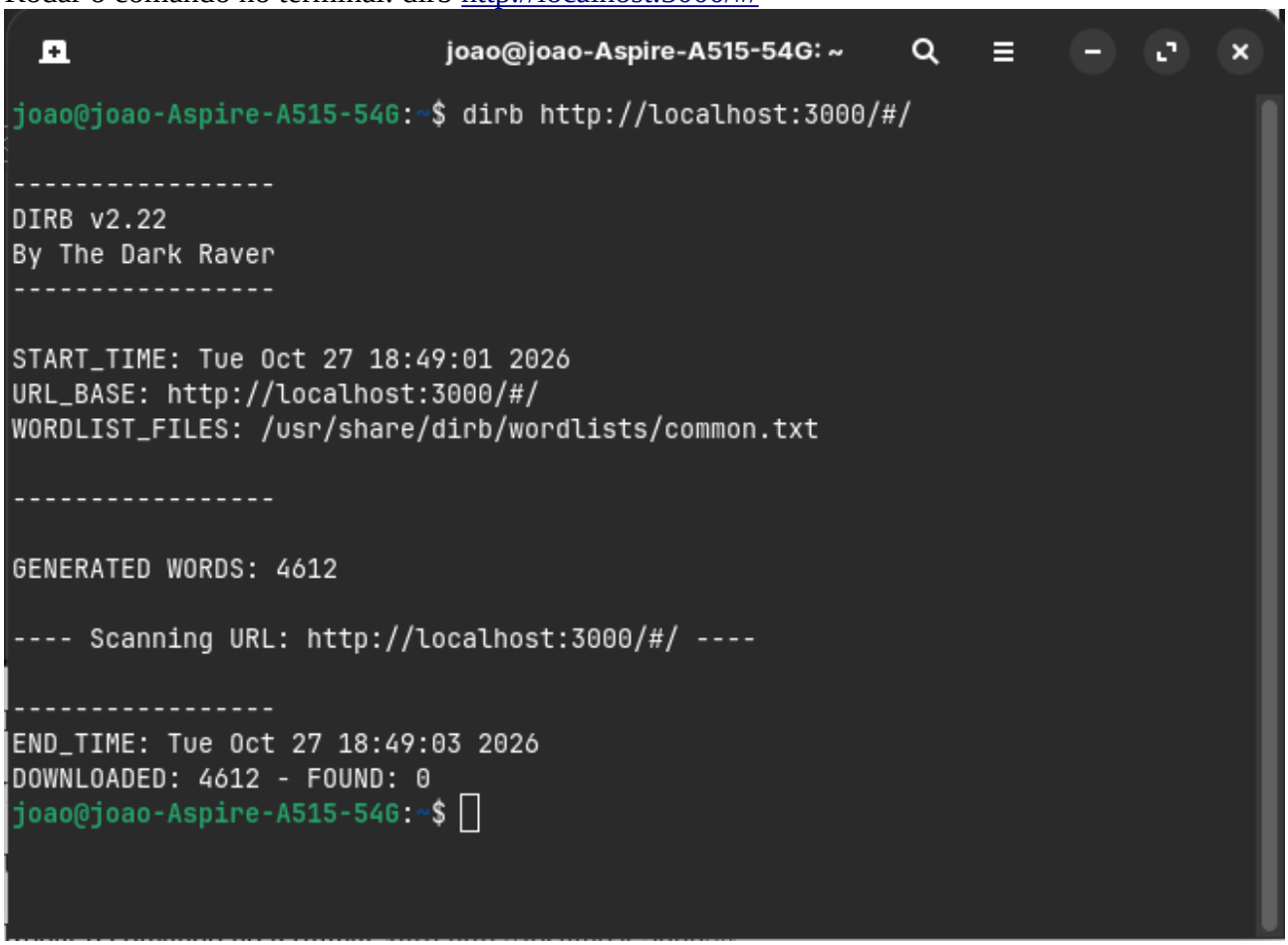


Email da conta de admin: admin@juice-sh.op

Teste 2: Analise de endpoints ocultos

Utilizando a ferramenta dirbuster para encontrar os endpoints ocultos.

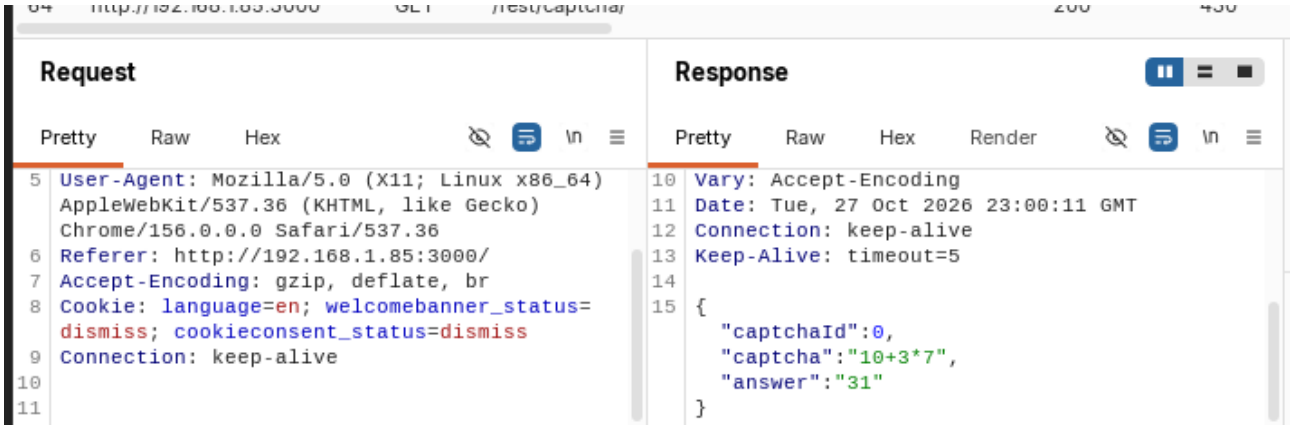
Rodar o comando no terminal: dirb http://localhost:3000/#/



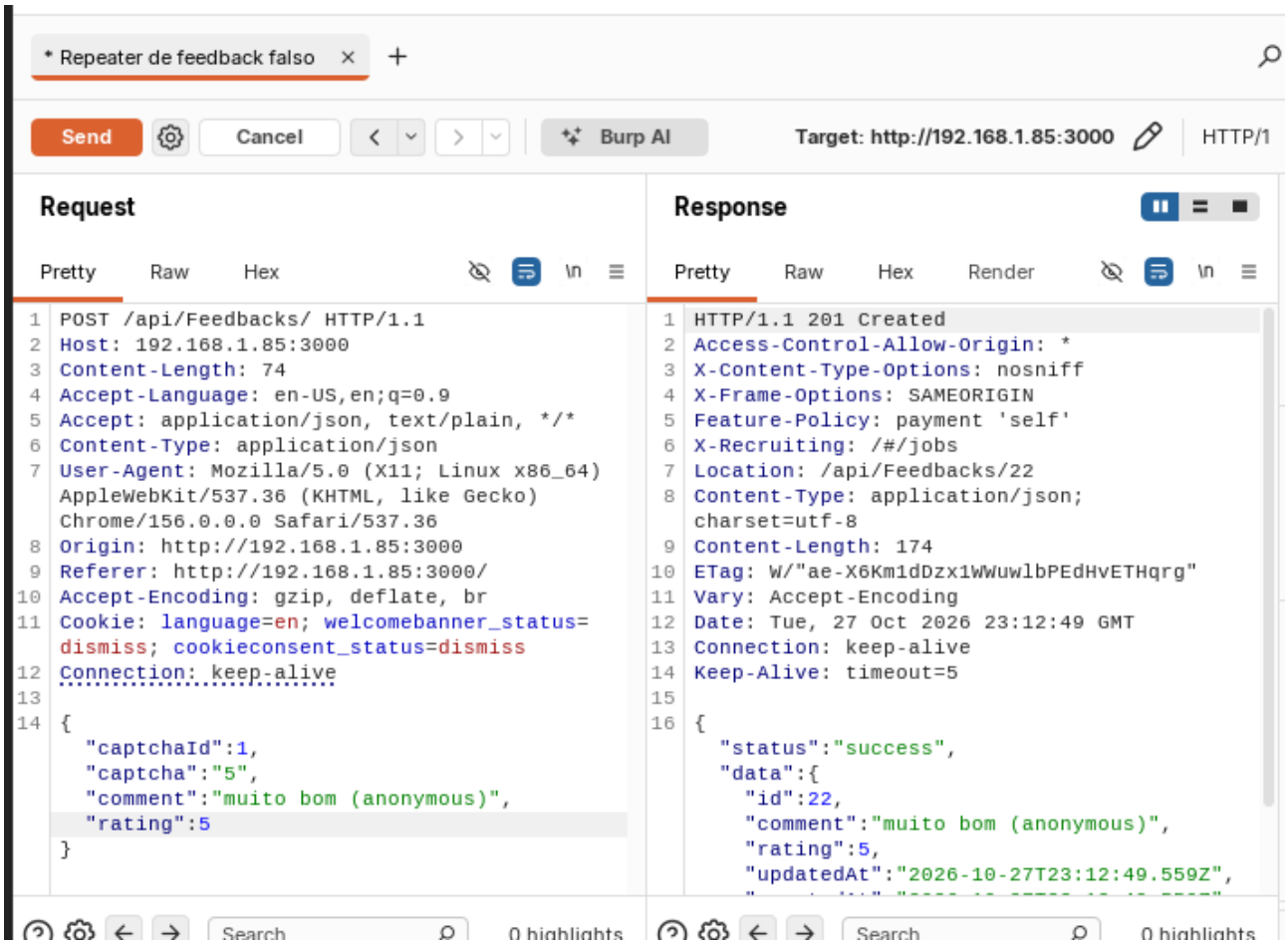
Não foi encontrado nenhum.

Teste 3: Usando o Burp Suit (foi feito em outro computador e o link da imagem do docker alterado)

- O primeiro teste, ao clicar para mandar um feedback, temos um captcha que conseguimos ver a resposta



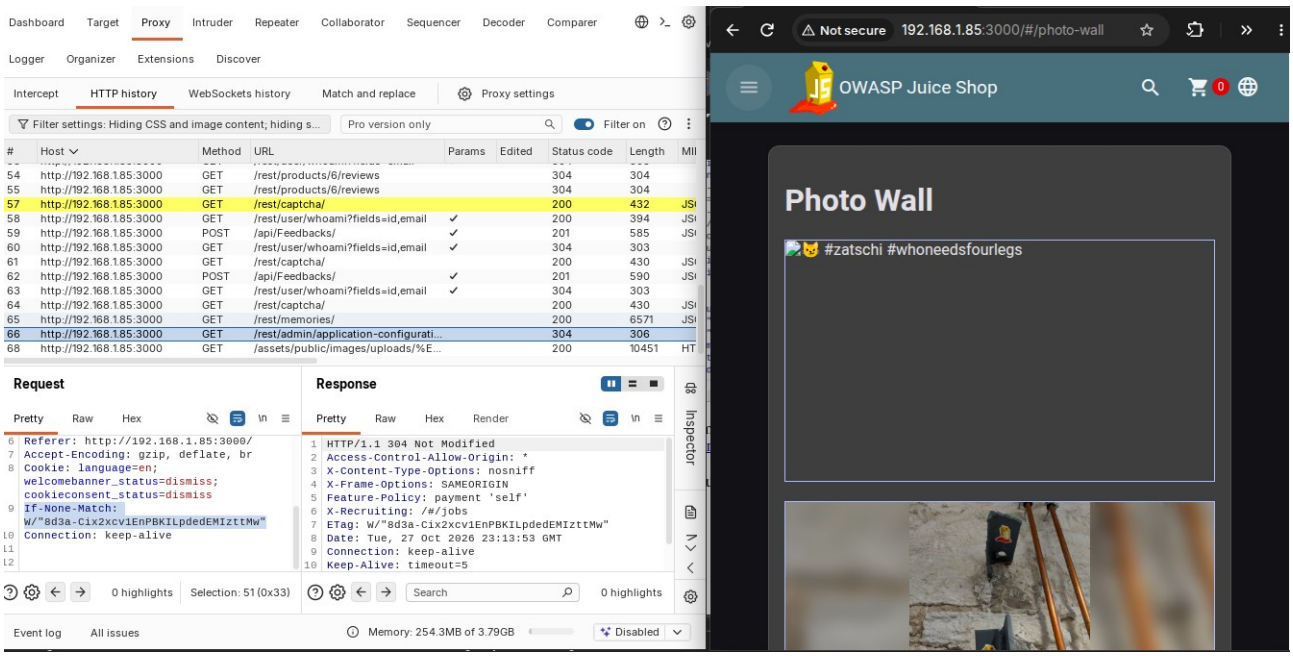
Isso nos possibilita a mandar feedbacks falsos com o repeater na requisição POST de feedback.



F

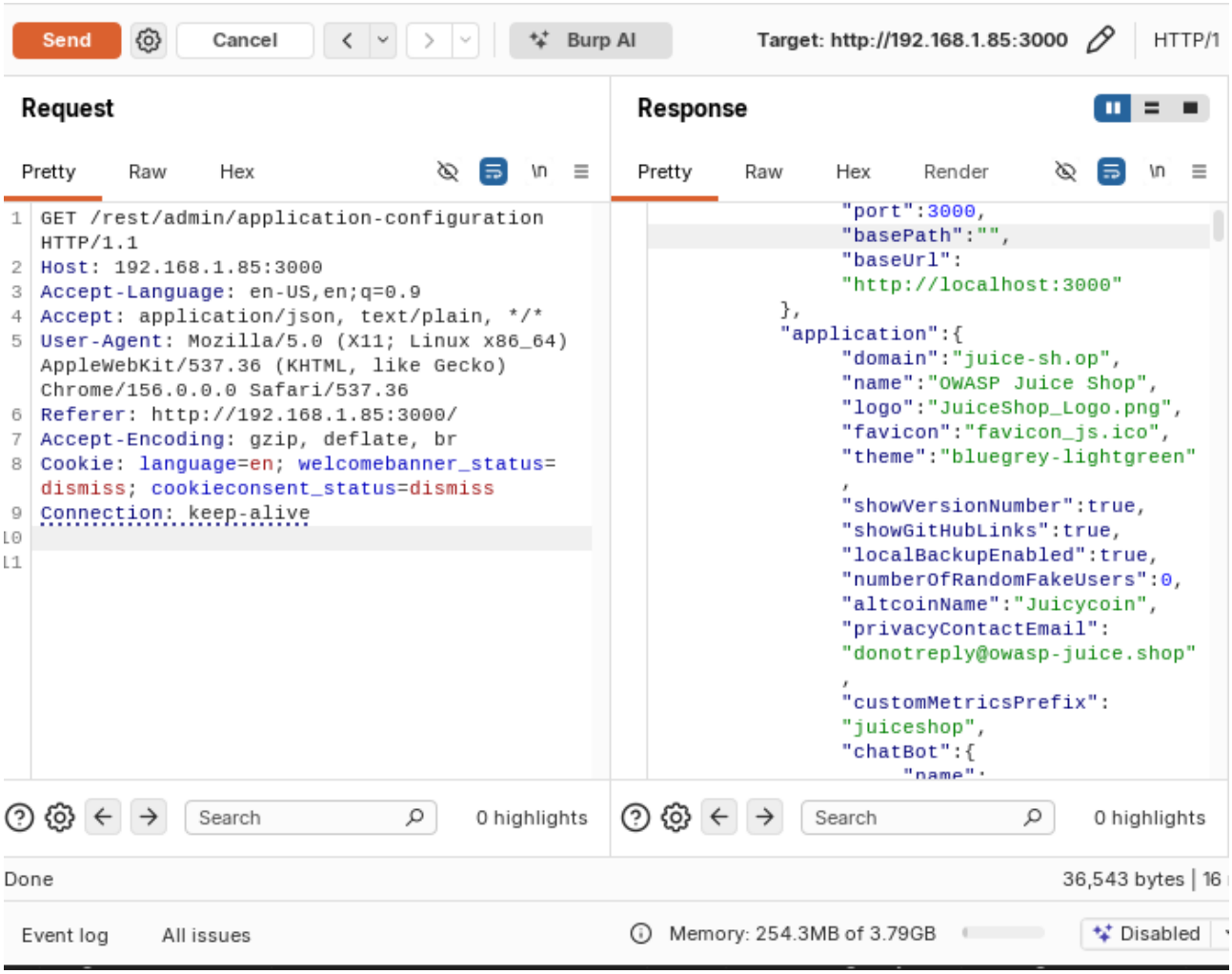
- Indo na aba de fotos, percebemos que ao abri-lo abrimos um endpoint chamado http://192.168.1.85:3000/rest/admin/application-configuration

Mandando ele para a aba de repeater, podemos alterar um pouco a requisição.

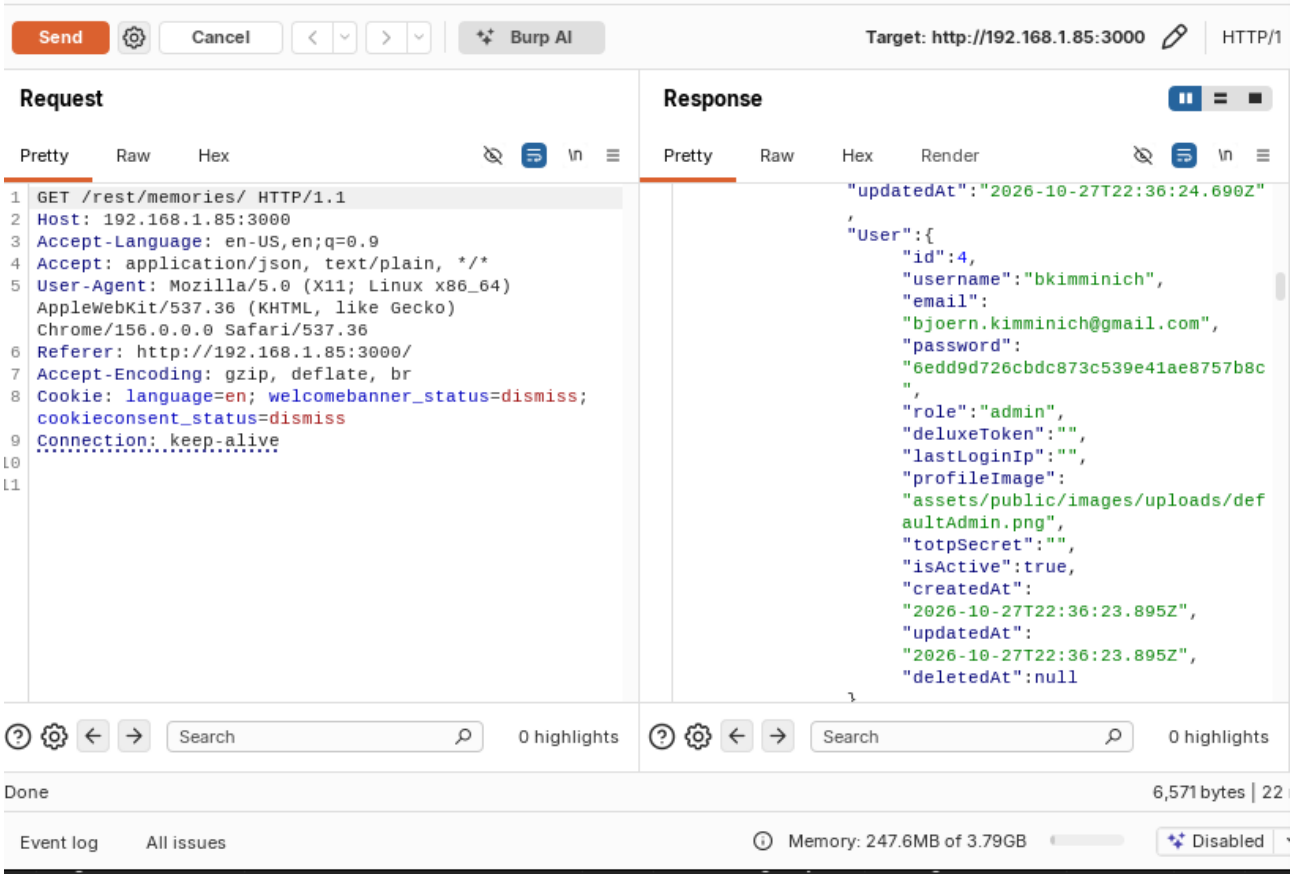


F

Ao retirar If-None-Match: W/"8d3a-Cix2xcv1EnPBKILpdedEMIzttMw" da requisição e enviá-la. Temos as seuintes informações:

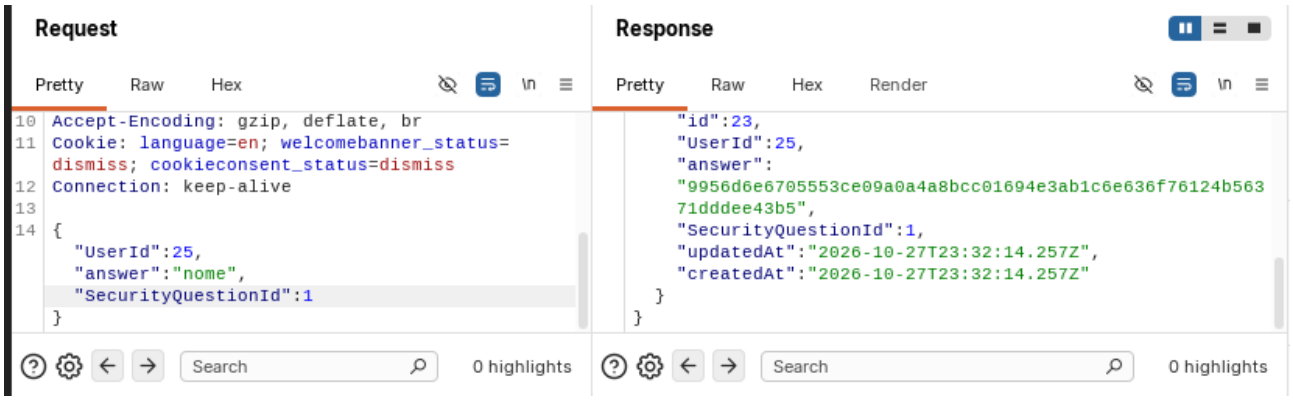


Temos também o endpoint /rest/memories/, ao olharmos as respostas das requisiçoes, vemos que ele retorna os dados dos usuarios que adicionaram as fotos.



Em especial, temos usuarios com cargo de admin.

Ao criar uma conta, voltamos para a tela de login e descobrimos que o endpoint /api/SecurityAnswers/ aparace, nele temos a resposta da pergunta de segurança (em hash) pelo id do usuario.



A partir disso, parei de tentar buscar informações por esse meio.

Teste 4: Observando o site no navegador.

No produto 1, temos feedbacks de clientes. Em um desses, podemos ver o autor: admin@juice-sh.op

Testando URLS por palavras padrao, consequimos acessar a pagina de admin com o endpoint /administration

